

PENTESTER TACTICPT-01

SOCIAL ENGINEERING - PRETEXTING ATTACK

TACTIC TYPE: Initial Access / Social Engineering
TARGET VECTORS: SOCIAL_ENGINEERING, CREDENTIAL_ABUSE
DIFFICULTY: BASIC (defeat DC 12)
TEACHING POINT: Social engineering exploits human psychology and organizational process gaps. Technology alone cannot defend against this; training and procedures are essential.

DESCRIPTION
A pentester calls your IT helpdesk impersonating a VIP executive. They claim to be traveling without their laptop and need emergency access to critical systems. They pressure the helpdesk with urgency and authority. Can they bypass your security procedures?

ATTACK DETAILS
Targets: User security training gaps, process enforcement;
Success indicates: Social engineering protocols aren't followed;
Blue Team rolls 1d20 to resist;

DEFENDING DEFENSES
D-02 (User Security Training): +2 bonus (staff trained to verify callers); D-07 (MFA): +1 bonus (second factor still required); D-23 (IR Program & Runbooks): +2 bonus (clear escalation procedures);

OUTCOME
Blue Team Succeeds (12+): Helpdesk follows proper verification procedures, attacker is denied; Blue Team Fails: Attacker gains credentials or system access; Blue Team must deploy additional defenses;

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-02

MALWARE EVASION - LIVING-OFF-THE-LAND TECHNIQUE

TACTIC TYPE: Persistence & Execution
TARGET VECTORS: MALWARE, CREDENTIAL_ABUSE
DIFFICULTY: INTERMEDIATE (defeat DC 13)
TEACHING POINT: Signature-based defenses are insufficient against sophisticated attackers. Behavioral detection and proactive hunting are essential for modern threats.

DESCRIPTION
A pentester delivers a payload that uses only built-in Windows tools (PowerShell, scheduled tasks, registry modifications, WMI) to maintain persistence and establish a beachhead. No suspicious files, no external C2 traffic—just legitimate Windows features weaponized. Can your defenses detect this?

ATTACK DETAILS
Targets: Traditional antivirus, signature-based detection;
Success indicates: Blind spot in malware detection strategy; Blue Team rolls 1d20 to detect and block;

DEFENDING DEFENSES
D-06 (Basic Antivirus): +1 bonus only (signatures don't catch living-off-the-land); D-08 (EDR): +3 bonus (behavioral detection catches anomalous PowerShell/schtasks); D-13 (Threat Hunting): +2 bonus (proactive hunting finds MITRE ATTACK techniques); D-14 (Memory Forensics): +2 bonus (finds injected code in memory);

OUTCOME
Blue Team Succeeds (13+): EDR or threat hunting detects the attack before persistence is established; Blue Team Fails: Attacker establishes persistent access; Blue Team must escalate incident response;

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-03

CREDENTIAL DUMPING - MIMIKATZ ATTACK

TACTIC TYPE: Privilege Escalation / Credential Access
TARGET VECTORS: CREDENTIAL_ABUSE, MALWARE
DIFFICULTY: INTERMEDIATE (defeat DC 13)
TEACHING POINT: Privileged credential protection is critical. Credential Guard is the gold standard for endpoint protection. Service account password rotation and vaults prevent cached credential abuse.

DESCRIPTION
A pentester with local admin privileges attempts to dump LSASS memory and extract cached domain credentials using Mimikatz. These credentials could then be used for lateral movement and privilege escalation. Can your endpoint defenses prevent this?

ATTACK DETAILS
Targets: LSASS memory protection, credential storage hardening;
Success indicates: Weak credential protection on endpoints; Blue Team rolls 1d20 to block the attack;

DEFENDING DEFENSES
D-07 (MFA): +1 bonus only (doesn't protect cached credentials); D-12 (Password Vault): +2 bonus (service accounts in vault aren't in LSASS); D-14 (Memory Forensics): +2 bonus (detects LSASS tampering); D-16 (Credential Guard & Secure Boot): +4 bonus (isolates LSASS in virtualized container—primary defense); D-08 (EDR): +2 bonus (alerts on suspicious LSASS access);

OUTCOME
Blue Team Succeeds (13+): Credential Guard blocks the attack or EDR detects the attempt; Blue Team Fails: Domain credentials compromised; Blue Team loses future rolls vs. credential-based attacks (-1 penalty for remaining game);

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-04

LATERAL MOVEMENT - NETWORK TRAVERSAL

TACTIC TYPE: Lateral Movement
TARGET VECTORS: NETWORK, CREDENTIAL_ABUSE
DIFFICULTY: INTERMEDIATE (defeat DC 13)
TEACHING POINT: Flat networks are indefensible. Network segmentation combined with zero-trust access controls are essential. Honeypots are low-cost but highly effective deterrents.

DESCRIPTION
A pentester with access to one workstation attempts to move laterally across your network using SMB share enumeration, pass-the-hash attacks, and exploitation of unsecured share access. Can your network architecture and controls prevent this?

ATTACK DETAILS
Targets: Network segmentation, share access controls; Success indicates: Flat network with unrestricted SMB traffic; Blue Team rolls 1d20 + architecture modifiers;

DEFENDING DEFENSES
D-04 (Firewall Rules): +1 bonus (blocks some traffic, but not SMB on internal network); D-09 (Network Segmentation): +3 bonus (restricts SMB traffic between segments); D-10 (SIEM Correlation): +2 bonus (detects lateral movement patterns); D-15 (Honeypots): +2 bonus (attacker triggers canary token); D-20 (Zero Trust Access): +3 bonus (even lateral access requires authentication);

OUTCOME
Blue Team Succeeds (13+): Network segmentation or honeypots stop the attack; Blue Team Fails: Attacker establishes foothold on file server or domain controller; future defense deployments cost 1.5x Budget;

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-05

PRIVILEGE ESCALATION - UNPATCHED KERNEL EXPLOIT

TACTIC TYPE: Privilege Escalation
TARGET VECTORS: KERNEL, WEX_EXPLOIT
DIFFICULTY: ADVANCED (defeat DC 14)
TEACHING POINT: Patch management is one of the highest-ROI security controls. Unpatched systems are low-hanging fruit for attackers. Automated patching and vulnerability scanning are essential.

DESCRIPTION
A pentester discovers an unpatched vulnerability in a critical Windows kernel or third-party driver. They develop a local privilege escalation exploit that elevates from user to SYSTEM privileges. Can your patch management and detection systems catch this?

ATTACK DETAILS
Targets: Patch management gaps, detection of privilege escalation; Success indicates: Unpatched systems or poor vulnerability management; Blue Team rolls 1d20 to patch or detect;

DEFENDING DEFENSES
D-03 (Windows Patching): +3 bonus (prevents the vulnerability from existing); D-05 (Log Centralization): +1 bonus (may detect unusual privilege elevation attempts); D-08 (EDR): +3 bonus (behavioral detection alerts on privilege escalation); D-13 (Threat Hunting): +2 bonus (proactive hunting finds unpatched systems);

OUTCOME
Blue Team Succeeds (14+): Patch management or EDR prevents or detects the exploit before escalation; Blue Team Fails: Attacker gains system-level access; all subsequent attacks get +1 bonus, all defensive deployments get -1 penalty for remainder of game;

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-06

DATA EXFILTRATION - UNMONITORED CHANNEL

TACTIC TYPE: Exfiltration
TARGET VECTORS: DATA_EXFIL, NETWORK
DIFFICULTY: ADVANCED (defeat DC 14)
TEACHING POINT: DLP and network monitoring are essential for preventing data loss. Organizations must understand their critical data flows and monitor them accordingly.

DESCRIPTION
A pentester with network access attempts to exfiltrate sensitive data (customer database, source code, trade secrets) via an unmonitored channel: DNS tunneling, steganography in image uploads, or a rogue cloud storage account. Can your DLP and monitoring systems catch this?

ATTACK DETAILS
Targets: Data loss prevention, network monitoring blind spots;
Success indicates: Unsupervised data channels or weak DLP enforcement; Blue Team rolls 1d20 to detect and block;

DEFENDING DEFENSES
D-04 (Firewall Rules): +1 bonus (may block some exfil channels); D-05 (Log Centralization): +1 bonus (may reveal unusual network traffic); D-10 (SIEM Correlation): +2 bonus (detects anomalous data transfer patterns); D-11 (DLP): +4 bonus (primary defense against data exfil); D-22 (SIEM): +2 bonus (detects data access and transfer anomalies); D-24 (Threat Intelligence): +1 bonus (identifies known C2 domains/IPs);

OUTCOME
Blue Team Succeeds (14+): DLP or network monitoring detects and blocks the exfil attempt; Blue Team Fails: Data is exfiltrated; Blue Team immediately loses the game (breach is complete);

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-07

SUPPLY CHAIN COMPROMISE - TRUSTED SOFTWARE UPDATE

TACTIC TYPE: Initial Access / Persistence
TARGET VECTORS: MALWARE, WEX_EXPLOIT
DIFFICULTY: ADVANCED (defeat DC 14)
TEACHING POINT: Trust is not security. Even legitimate vendors can be compromised. Behavioral detection, code signing verification, and staged rollouts are essential.

DESCRIPTION
A pentester compromises a software vendor that your organization trusts. They inject malicious code into a legitimate update that your organization automatically deploys. The malware is signed with the vendor's legitimate certificate. Can you detect and prevent this?

ATTACK DETAILS
Targets: Update management, supply chain security, behavioral detection; Success indicates: Over-trust in vendor updates, poor verification procedures; Blue Team rolls 1d20 to detect or prevent;

DEFENDING DEFENSES
D-03 (Windows Patching): +0 bonus (legitimate patch—can't be distinguished); D-06 (Antivirus): +1 bonus only (legitimate signature—won't help); D-08 (EDR): +3 bonus (behavioral detection catches malicious activity after installation); D-13 (Threat Hunting): +2 bonus (proactive hunting for suspicious post-update behavior); D-17 (Malware Sandbox): +2 bonus (detonates update before deployment); D-21 (Container Security): +2 bonus (prevents compromise spread in containerized environments);

OUTCOME
Blue Team Succeeds (14+): EDR or threat hunting detects malicious behavior before widespread compromise; Blue Team Fails: Supply chain compromise spreads across organization; -2 penalty to all defense rolls for remainder of game;

INCIDENT ZERO · HARDENING

PENTESTER TACTICPT-08

INSIDER THREAT - MALICIOUS ADMINISTRATOR

TACTIC TYPE: Privilege Abuse / Data Exfiltration
TARGET VECTORS: CREDENTIAL_ABUSE, DATA_EXFIL, NETWORK
DIFFICULTY: EXPERT (defeat DC 15)
TEACHING POINT: Insider threats are one of the hardest problems in security. Prevention is impossible; detection is essential. Privileged access management, behavioral monitoring, and immutable audit logs are critical.

DESCRIPTION
A pentester acts as a disgruntled administrator with legitimate system access. They use their privileges to bypass security controls, disable logging, create backdoor accounts, and exfiltrate sensitive data. Can your controls prevent insider threats?

ATTACK DETAILS
Targets: Administrative account monitoring, privilege abuse detection; Success indicates: Weak monitoring of privileged access, overly broad admin permissions; Blue Team rolls 1d20 to detect and prevent;

DEFENDING DEFENSES
D-05 (Log Centralization): +2 bonus (immutable offsite logs prevent tampering); D-07 (MFA): +1 bonus (makes it harder to create backdoor accounts); D-10 (SIEM Correlation): +2 bonus (detects unusual admin activity patterns); D-12 (Password Vault): +2 bonus (requires approval/audit for privileged access); D-20 (Zero Trust Access): +3 bonus (even admins require proper authorization for sensitive access); D-21 (SIEM): +3 bonus (behavioral analytics detect insider threats); D-23 (IR Program & Runbooks): +1 bonus (clear escalation for suspicious admin activity);

OUTCOME
Blue Team Succeeds (15+): Monitoring detects unauthorized admin activity before damage; Blue Team Fails: Insider exfiltrates data and disables controls; Blue Team loses game immediately and additional penalties apply to Disaster Recovery module (if played next);

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-01

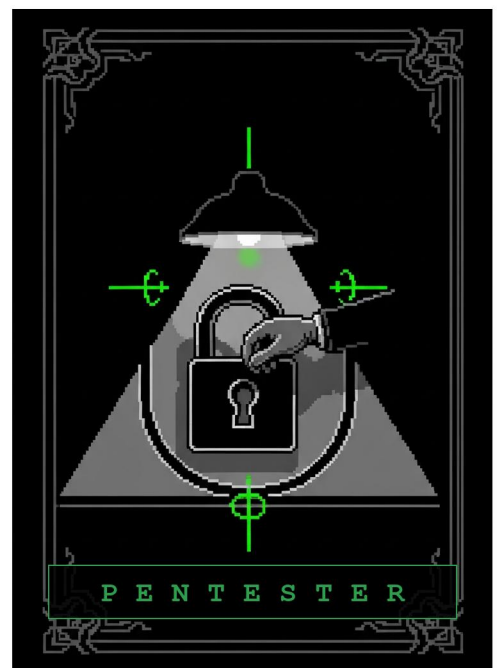
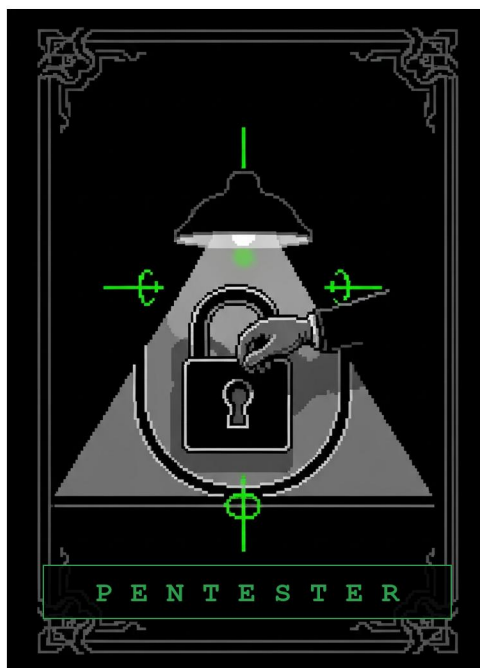
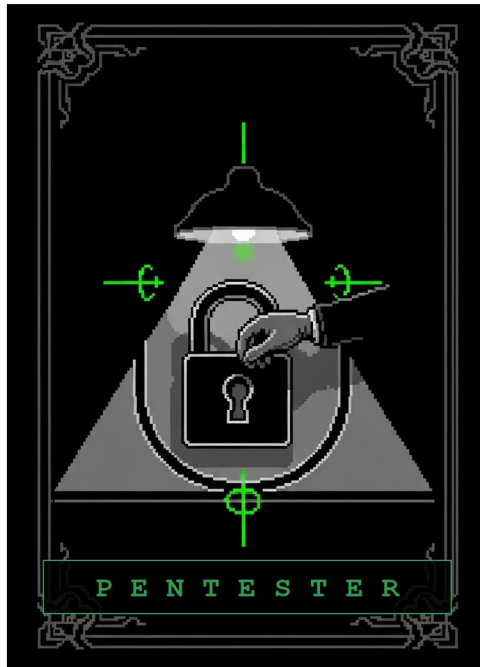
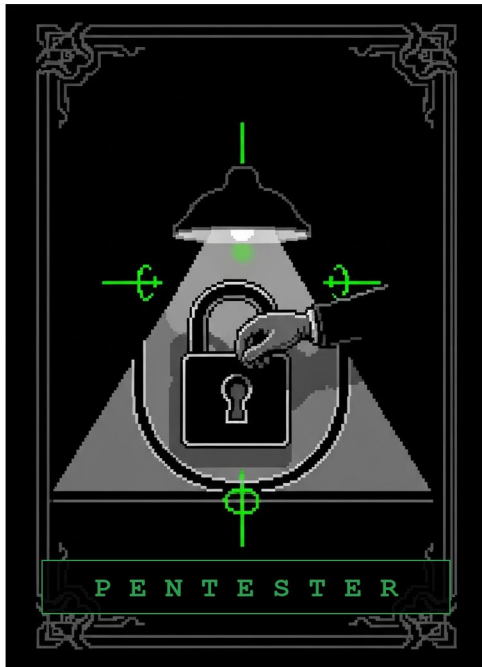
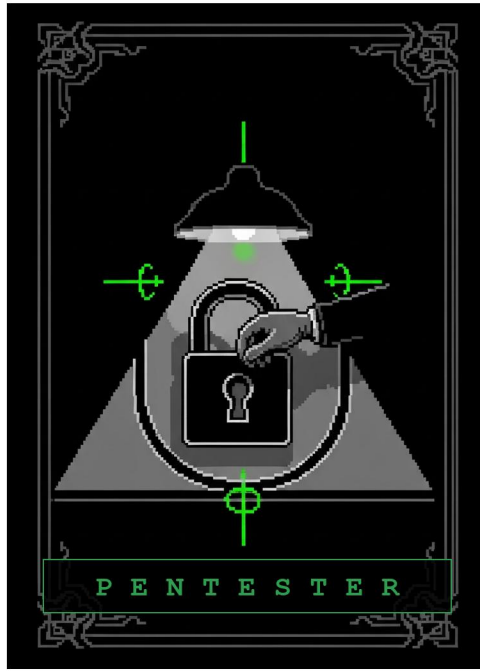
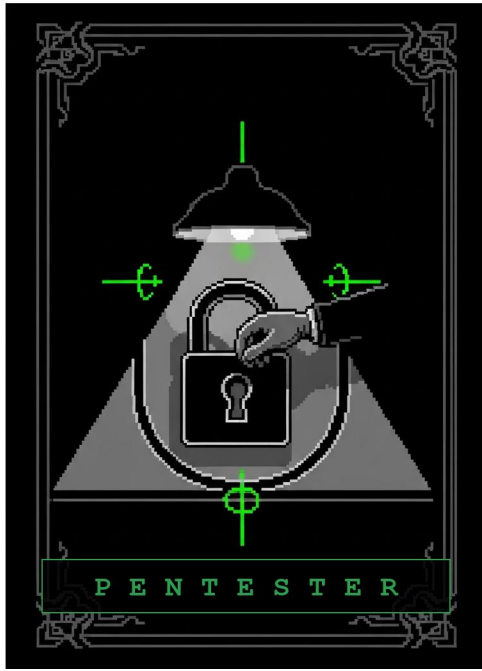
EMAIL AUTHENTICATION SETUP

TIER: BASIC (10 Budget)
VECTOR: SOCIAL_ENGINEERING
EFFECT: Blocks phishing emails claiming to be from your domain. Requires attackers to find alternative vectors.

USED AGAINST: T-01 (Phishing Campaign)

Deploy SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), and DMARC (Domain Message Authentication, Reporting & Conformance) to prevent email spoofing.

INCIDENT ZERO · HARDENING



DEFENSE CARD

D-02

USER SECURITY TRAINING

TIER: BASIC (10 Budget)
VECTOR: SOCIAL_ENGINEERING
EFFECT: Reduces successful phishing rate by 70-80%. Users become your first line of defense.
USED AGAINST: T-01, T-02 (Phishing, Watering Hole)

Conduct phishing awareness training for all staff. Teach recognition of suspicious links, sender spoofing, urgency tactics, and credential harvesting attempts.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-03

WINDOWS UPDATE PATCHING

TIER: BASIC (10 Budget)
VECTOR: WEB_EXPLOIT
EFFECT: Closes browser and kernel vulnerabilities. Prevents watering hole and exploit kit attacks.
USED AGAINST: T-02 (Watering Hole), T-05 (Privilege Escalation)

Deploy automated Windows Update management across all systems. Establish patch deployment timelines (critical = 48 hours, high = 2 weeks).

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-04

NETWORK FIREWALL RULES

TIER: BASIC (10 Budget)
VECTOR: NETWORK
EFFECT: Prevents early-stage lateral movement and C2 beaconing. Slows attacker reconnaissance.
USED AGAINST: T-04 (Lateral Movement), T-09 (C2 Beaconing)

Deploy perimeter firewall rules to block unauthorized outbound protocols. Default-deny for unusual ports and known malware C2 domains.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-05

LOG CENTRALIZATION

TIER: BASIC (10 Budget)
VECTOR: MALWARE
EFFECT: Makes local log tampering difficult. Provides investigative visibility into attacker activities. Foundation for threat hunting.
USED AGAINST: T-07, T-08 (Persistence attacks)

Deploy centralized log aggregation (syslog, Splunk, ELK). Forward Windows Event Logs, firewall logs, DNS queries, and proxy logs to central SIEM.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-06

BASIC ANTIVIRUS DEPLOYMENT

TIER: BASIC (10 Budget)
VECTOR: MALWARE
EFFECT: Catches known malware variants. Does not detect zero-day or polymorphic malware. Useful as part of defense-in-depth.
USED AGAINST: T-05, T-07, T-08 (Malware-based attacks)

Deploy signature-based antivirus across all endpoints. Enable automatic definition updates (daily). Configure real-time file and email scanning.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-19

BACKUP & DISASTER RECOVERY

TIER: BASIC (10 Budget) *(v2.2 – retired from ELITE; 3-2-1 backups are fundamental hygiene)*
VECTOR: MALWARE
EFFECT: Enables rapid recovery from ransomware. Ensures data availability even if primary systems are compromised. Critical for business continuity.
USED AGAINST: T-07, T-08, T-10, T-11, T-12 (Persistence and exfil attacks)

Implement 3-2-1 backup strategy: 3 copies of data, 2 different storage types, 1 offsite copy. Test restore procedures quarterly.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-23

IR PROGRAM & RUNBOOKS

TIER: BASIC (10 Budget) *(v2.2 – retired from ELITE and renamed from "Incident Response Playbooks" to avoid confusion with the Hardening "Create Playbook" action)*
VECTOR: NETWORK
EFFECT: Enables faster, more coordinated response when incidents occur. Reduces confusion during high-pressure situations. Improves incident containment and recovery time.
USED AGAINST: T-09, T-10, T-11, T-12 (All C2 & Exfil attacks)

Establish an incident response program with detailed runbooks for common scenarios: malware infection, data exfiltration, ransomware, insider threats, supply chain compromise. Include roles, responsibilities, communication plans.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-07

MULTI-FACTOR AUTHENTICATION (MFA)

TIER: ADVANCED (15 Budget)
VECTOR: CREDENTIAL_ABUSE
EFFECT: Makes compromised credentials useless without the second factor. Blocks credential stuffing attacks.
USED AGAINST: T-03 (Compromised Credentials), T-06 (Mimikatz)

Deploy MFA for all remote access (VPN, RDP), email, and admin portals. Use authenticator apps or hardware tokens (not SMS).

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-08

EDR (ENDPOINT DETECTION & RESPONSE)

TIER: ADVANCED (15 Budget)
VECTOR: MALWARE
EFFECT: Detects living-off-the-land attacks (PowerShell, cmd, scheduled tasks). Provides deep visibility into attack progression.
USED AGAINST: T-05 (Priv Esc), T-07, T-08 (Persistence)

Deploy EDR agent on all endpoints. Monitor process execution, file creation, registry modifications, and memory injection attempts. Enable behavioral analytics.

INCIDENT ZERO · HARDENING



DEFENSE CARD

D-09

NETWORK SEGMENTATION

TIER: ADVANCED (15 Budget)
VECTOR: NETWORK
EFFECT: Prevents lateral movement via SMB and other internal protocols. Limits blast radius of compromise.
USED AGAINST: T-04 (Lateral Movement), T-06 (Credential Dumping spread)

Implement VLANs and microsegmentation to separate user workstations from servers. Deploy firewall rules between segments. Implement zero-trust network access controls.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-10

SIEM CORRELATION RULES

TIER: ADVANCED (15 Budget)
VECTOR: NETWORK
EFFECT: Correlates events across logs to detect multi-step attacks. Enables faster investigation and response.
USED AGAINST: T-04, T-05, T-06, T-07, T-08, T-09 (Detection across entire chain)

Create SIEM rules to detect attack patterns: failed login spikes, privilege escalation attempts, unusual process creation, scheduled task creation, and data exfil indicators.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-11

DATA LOSS PREVENTION (DLP)

TIER: ADVANCED (15 Budget)
VECTOR: DATA_EXFIL
EFFECT: Prevents SQL database exfiltration and bulk data theft. Detects unusual data access patterns. Enforces data security policies.
USED AGAINST: T-10, T-11, T-12 (Data exfiltration attacks)

Deploy DLP to monitor outbound data transfers. Classify sensitive data (customer PII, source code, trade secrets). Block or alert on unauthorized transfers.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-12

PASSWORD MANAGER & VAULT

TIER: ADVANCED (15 Budget)
VECTOR: CREDENTIAL_ABUSE
EFFECT: Prevents credential reuse attacks. Makes credential stuffing difficult. Provides audit trail for compliance and incident investigation.
USED AGAINST: T-03, T-06 (Credential attacks)

Deploy enterprise password vault (CyberArk, HashiCorp Vault). Enforce strong unique passwords. Implement password rotation policies for service accounts.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-18

INTRUSION PREVENTION SYSTEM (IPS)

TIER: ADVANCED (15 Budget) *(v2.2 – retired from ELITE; IPS/WAF appliances are standard mid-tier controls)*
VECTOR: WEB_EXPLOIT
EFFECT: Blocks exploitation attempts in transit. Prevents watering hole and web exploit attacks. Most effective when combined with patching.
USED AGAINST: T-02 (Watering Hole), T-05 (Exploits)

Deploy network-based IPS with exploit signatures. Monitor for known CVE exploitation patterns. Configure WAF (Web Application Firewall) rules for SQL injection, XSS, and OWASP Top 10 attacks.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-24

THREAT INTELLIGENCE INTEGRATION

TIER: ADVANCED (15 Budget) *(v2.2 – retired from ELITE; community feeds like MISP/OTX are affordable)*
VECTORS: NETWORK, DATA_EXFIL *(v2.2 – dual-tagged; counts as a match for either vector)*
EFFECT: Enables faster detection of known malicious IPs and domains. Identifies emerging threats targeting your industry. Reduces detection time from days to minutes.
USED AGAINST: T-09 (C2 Beacons), T-10, T-11, T-12 (Exfil detection)

Subscribe to threat intelligence feeds (MISP, VirusTotal, AlienVault OTX). Integrate IOCs (Indicators of Compromise) into firewall, SIEM, and proxy. Participate in information sharing communities.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-13

THREAT HUNTING PROGRAM

TIER: ELITE (25 Budget)
VECTOR: MALWARE
EFFECT: Finds advanced attacks that bypass signature-based detection. Detects LSASS dumping, scheduled task persistence, and registry backdoors. Reduces dwell time significantly.
USED AGAINST: T-05, T-07, T-08 (Advanced persistence)

Establish proactive threat hunting using MITRE ATT&CK framework. Hunt for living-off-the-land techniques, anomalous processes, suspicious registry changes, and memory injection.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-14

MEMORY FORENSICS

TIER: ELITE (25 Budget)
VECTOR: MALWARE
EFFECT: Detects Mimikatz attacks and credential harvesting. Reveals attacker activities hidden from disk forensics. Critical for identifying advanced persistence mechanisms.
USED AGAINST: T-06 (Mimikatz), T-07, T-08 (In-memory attacks)

Deploy memory capture and analysis (Volatility, Memoryze). Create memory images of suspicious systems. Analyze for credential dumping, injected code, and rootkits.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-15

DECEPTION TECHNOLOGY (HONEYPOTS)

TIER: ELITE (25 Budget)
VECTOR: NETWORK
EFFECT: Any access to honeypots indicates active compromise. Detects lateral movement with zero false positives. Slows attacker progress and forces reconnaissance.
USED AGAINST: T-04 (Lateral Movement), T-06 (Credential abuse)

Deploy decoy systems (fake file servers, databases, credentials) to detect lateral movement. Create canary tokens that alert when accessed.

INCIDENT ZERO · HARDENING



DEFENSE CARD

D-16

CREDENTIAL GUARD & SECURE BOOT

TIER: ELITE (25 Budget)

VECTOR: CREDENTIAL_ABUSE

EFFECT: Makes Mimikatz credential dumping ineffective. Prevents bootloader manipulation. Ensures firmware integrity. Blocks entire classes of early-boot attacks.

USED AGAINST: T-06 (Mimikatz), T-07, T-08 (Persistence)

Enable Windows Credential Guard to isolate LSASS in virtualized container. Implement UEFI Secure Boot to prevent bootkit attacks. Enable TPM attestation.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-17

ADVANCED MALWARE SANDBOX

TIER: ELITE (25 Budget)

VECTOR: MALWARE

EFFECT: Detects zero-day malware and unknown exploits. Analyzes evasion tactics. Generates detection rules for SIEM. Prevents spread of novel malware.

USED AGAINST: T-05 (Privilege Escalation), T-07, T-08 (Malware persistence)

Deploy advanced sandboxing solution (Cuckoo, Detonate, hybrid-analysis). Analyze suspicious files/URLs in isolated environments. Generate behavioral indicators and YARA rules.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-20

ZERO TRUST ACCESS CONTROL

TIER: ELITE (25 Budget)

VECTOR: CREDENTIAL_ABUSE

EFFECT: Eliminates implicit trust based on network location. Even compromised devices cannot access sensitive resources without proper authentication and behavior validation.

USED AGAINST: T-03, T-06 (Credential abuse), T-04 (Lateral movement)

Implement zero-trust architecture: verify every access request regardless of source. Deploy device identity, user identity, and behavior analytics. Implement conditional access policies.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-21

CONTAINER SECURITY & ORCHESTRATION

TIER: ELITE (25 Budget)

VECTOR: MALWARE

EFFECT: Detects container escape attempts. Prevents vulnerable images from running. Limits lateral movement within containerized environments. Critical for modern cloud applications.

USED AGAINST: T-05 (Priv Esc), T-04 (Lateral Movement in cloud)

Deploy container runtime security (Falco, Sysdig). Implement image scanning for vulnerabilities. Use policy enforcement engines (OPA/Gatekeeper). Implement network policies for container segmentation.

INCIDENT ZERO · HARDENING

DEFENSE CARD

D-22

SECURITY INFORMATION & EVENT MANAGEMENT (SIEM)

TIER: ELITE (25 Budget)

VECTOR: NETWORK

EFFECT: Provides centralized visibility into all security events. Enables rapid threat detection and investigation. Foundation for mature incident response program.

USED AGAINST: T-04, T-06, T-07, T-08, T-09, T-10 (Detection across entire attack chain)

Deploy enterprise SIEM (Splunk, ELK, QRadar). Centralize logs from all sources. Implement automated correlation rules, threat intelligence integration, and incident response workflows.

INCIDENT ZERO · HARDENING

